PATCHBOUNTY // PROJECT 2 VISUAL ARCHITECTURE GUIDE

Autonomous 6-uAgent Open-Source Security Audit, Sandbox Exploit Proof & Dorado Escrow

Built by Atul Anand, Jeeya, and Vanshika for Fetch.ai Fetch-A-Thon 3.0

1. EXECUTIVE PROBLEM & ZERO-FALSE-POSITIVE SOLUTION

Open-source maintainers receive unverified AI bug reports while security researchers lack trustless instant payouts.

PatchBounty coordinates 6 Fetch.ai uAgents via AgentChatProtocol v0.3.0 + AgentPaymentProtocol v0.1.0.

Every vulnerability (CWE-89, CWE-78, CWE-22, CWE-502, CWE-327) is reproduced inside an isolated Python subprocess

before patching, then verified post-patch for AST compilation, exploit blocking, and unit regression pass.

2. SIX FETCH.AI UAGENTS SWARM ARCHITECTURE

- @patchbounty_coordinator: ASI:One Mailbox Coordinator, Two-Way Live Studio Mirror & Meta-Question Router
- @repo_hunter: Live GitHub Public REST API (api.github.com), Inline Snippet & Workspace Repo Scanner
- @vuln_auditor: Python AST Taint Analyzer & CVSS v3.1 Severity Scorer (Dual asi1 + asi1-mini)
- @exploit_verifier: Isolated Temp-Dir Subprocess Exploit Reproducer (Millisecond Proof, Zero Hallucinations)
- @patch_synthesizer: 3-Strategy Unified Git Diff Generator, Sealed Maintainer Ceiling & Honest Floor Guard
- @bounty_escrow: Live Fetch Dorado Testnet (0.05 TESTFET) Settlement, Anti-Replay & CancelPayment Safety

3. VERIFIED ON-CHAIN FETCH DORADO TESTNET SETTLEMENT PROOF

- Network: Fetch.ai Dorado Testnet (dorado-1) | Protocol: AgentPaymentProtocol v0.1.0
- Verified Block Height: #25805942 | Escrow Amount: 0.05 TESTFET (50000000000000000 atestfet)
- TX Hash: CAC1FFAB22AA5BC91ABDD1AF97E85C763F3905EC4441E3C2F49503AA50201601
- Maintainer Wallet: fetch1jvlze26g5ed2ua0unw0yc8pl7cp24sh2xwm9x2
- Researcher Wallet: fetch182wut09g9wfgctmcc9m0y67ck7t2fc9hldl2y7 (0% Platform Fee)

4. POST-CONFIRMATION ARTIFACTS & SEALED BUDGET PRIVACY

- Printable Maintainer Security Clearance PDF Card (includes private ceiling comparison, Merge PIN & TX Hash)
- Printable Researcher Bounty Receipt PDF Card (0% commission, maintainer private ceiling strictly hidden)
- 7-Day Coordinated Security Disclosure Calendar with separate Maintainer & Researcher .ics invites

LIVE STUDIO SCREENSHOT 1: 6-UAGENT CONSOLE, OPEN-INPUT FORM & SWARM ROSTER

PB // AI

PatchBounty — Autonomous Security Audit & Dorado Bounty Studio

6 Fetch.ai uAgents | Real AST + Isolated Sandbox Exploit & Diff Verification | Built by Atul Anand, Jeeya, and Vanshika

6 uAgents Online | ASI:One (asi1 + asi1-mini) | Fetch Dorado (0.05 TESTFET) | Hide Guided Form | Runtime Keys | Reset

@PATCHBOUNTY_COORDINATOR CONSOLE

READY

CWE-89 SQLi ($190) | CWE-78 Shell RCE ($175) | CWE-22 Path Traversal | CWE-502 Unsafe Eval | Below-Floor Test ($40)

PatchBounty Autonomous Security Swarm is online.
Enter any public GitHub repository URL (`https://github.com/owner/repo`), paste a Python module, use the Guided Bounty Form, or ask to scan one of the workspace microservices (`fintech_ledger_api`, `cloud_deploy_runner`, `doc_vault_storage`, `config_sync_engine`).

Ask a question, paste GitHub URL, or update 'budge

Send

OPEN-INPUT GUIDED BOUNTY AUDIT FORM

FREE-TEXT MULTI-SCOPE

Public GitHub URL or Workspace Module(s) (Open Free-Text)

targets/fintech_ledger_api

Security Audit Scope / Vulnerability Classes (Single or Multiple Items)

SQL Injection & Account Lookup Parameterization

Sealed Maintainer Bounty Ceiling in USD (Private — Hidden from Researchers)

190

Optional Inline Python Source Code Snippet

Optional: paste raw Python code to audit and patch directly in isolated sandbox...

Launch 6-uAgent Audit & Verify Patches

6-UAGENT FETCH.AI ACTIVE SWARM ROSTER

@patchbounty_coordinator
ASI:One Mailbox Coordinator, Intent Router & Payment Orchestrator
`agent1qdcr5z642euushvarck70vpg06g7hf2pz07vzvahf0cvssdnvg37u6ak6k7`

@repo_hunter
Live GitHub Public REST API & Repository Code Inspector
`agent1qvcd2kdp9d85hs23s0jp3xc5hug6vka3vlwp4vjh2gef0yxs6u8w2fj3tyr`

@vuln_auditor
Python AST Taint Control-Flow Analyzer & CVSS v3.1 Scorer
`agent1qwfz7dl3gf49rd8wwgl46hs2f2xp2uj5msqn7eergjgsrdwvflskk0uz6zv`

@exploit_verifier
Isolated Subprocess Sandbox Exploit Reproducer (Zero False Positives)
`agent1q0nwtsecx227ws7gv07l4y8uxhj49ys0pjjmr9e6p6q6m6aeqam3y6czv9t`

@patch_synthesizer
3-Strategy Unified Git Diff Synthesizer & Regression Gate
`agent1q2aaqx6ux44t4kglvz73c0a5ka6qrtz9seqvq9k69kc3rzqpsfy4j7lf3k2`

@bounty_escrow
Live Fetch Dorado Testnet (0.05 TESTFET) Settlement & CancelPayment Guard
`agent1qt8txhnxupkwc76zvvq4d4800g0dnzv64t2n3qzavdpe9psvkhze23539kx`

PB // AI **PatchBounty — Autonomous Security Audit & Dorado Bounty Studio**

6 Fetch.ai uAgents | Real AST + Isolated Sandbox Exploit & Diff Verification | Built by Atul Anand, Jeeya, and Vanshika

6 uAgents Online | ASI:One (asi1 + asi1-mini) | Fetch Dorado (0.05 TESTFET) | Hide Guided Form | Runtime Keys | Reset

@PATCHBOUNTY_COORDINATOR CONSOLE

PATCHES_VERIFIED

CWE-89 SQLi ($190) | CWE-78 Shell RCE ($175) | CWE-22 Path Traversal | CWE-502 Unsafe Eval | Below-Floor Test ($40)

PatchBounty Autonomous Security Swarm is online.
Enter any public GitHub repository URL (`https://github.com/owner/repo`), paste a Python module, use the Guided Bounty Form, or ask to scan one of the workspace microservices (`fintech_ledger_api`, `cloud_deploy_runner`, `doc_vault_storage`, `config_sync_engine`).

Scan fintech_ledger_api for SQL injection vulnerabilities under $190 USD

Verified `CWE-89` (CRITICAL | CVSS 9.8) in `targets/fintech_ledger_api/ledger_service.py` line 30.
- Pre-Patch Isolated Sandbox: Exploit Reproduced = True (54.55 ms)
- Post-Patch Verification: All 3 unified diffs compiled cleanly, blocked the exploit, and passed functional regression checks.
- Active Selection: Strategy Beta — Hardened Defense-in-Depth Patch at $174 USD (saved $86 USD vs standard ask).

Ask a question, paste GitHub URL, or update 'budge | Send

OPEN-INPUT GUIDED BOUNTY AUDIT FORM

FREE-TEXT MULTI-SCOPE

Public GitHub URL or Workspace Module(s) (Open Free-Text)

targets/fintech_ledger_api

Security Audit Scope / Vulnerability Classes (Single or Multiple Items)

SQL Injection & Account Lookup Parameterization

Sealed Maintainer Bounty Ceiling in USD (Private — Hidden from Researchers)

190

Optional Inline Python Source Code Snippet

Optional: paste raw Python code to audit and patch directly in isolated sandbox...

Launch 6-uAgent Audit & Verify Patches

LIVE 6-UAGENT TELEMETRY STREAM

[12:47:44 UTC] @patch_synthesizer — THREE_PATCHES_VERIFIED: All 3 candidate patches compiled cleanly, blocked CWE-89 in sandbox, and passed unit regression checks (no-api-key).

[12:47:44 UTC] @exploit_verifier — PRE_PATCH_SANDBOX_PROOF: Isolated sandbox executed in 54.55 ms | Exploit Reproduced: True | Baseline Unit Tests: PASS

[12:47:44 UTC] @vuln_auditor — AST_TAINT_CONFIRMED: Identified CWE-89 (CRITICAL CVSS 9.8) in

1. VERIFIED VULNERABILITY & ISOLATED SANDBOX REPRODUCTION (CWE-89 | CRITICAL CVSS 9.8)

ZERO FALSE POSITIVES

Target: `targets/fintech_ledger_api/ledger_service.py` (Line 30, function `lookup_account_by_owner`) — **SQL Injection via Unparameterized f-String Query Construction** (A03:2021-Injection)

ASI:One Principal Security Advisory (no-api-key): CWE-89 in `targets/fintech_ledger_api/ledger_service.py` (line 30) allowed untrusted input to reach a privileged execution sink during isolated sandbox reproduction (54.55 ms). Parameterized input binding and boundary validation eliminate the exploit vector with zero functional regressions.

BEFORE PATCH — Isolated Subprocess Exploit Test

Exploit Reproduced: **TRUE** (54.55 ms)

```
Sink: query = f"SELECT owner, tier, balance_inr FROM accounts WHERE owner = '{owner_handle}' AND tier != 'internal_admin'"
```

AFTER PATCH — Compile + Exploit Block + Regression Suite

AST Compile: **PASS** | Exploit Blocked: **TRUE** | Unit Tests: **PASS** (26.36 ms)

```
Verified Patch Digest SHA-256: 1d743ec800fa079e
```

2. NEGOTIATED REMEDIATION TIERS & MAINTAINER BOUNTY COMPARISON

YOUR SEALED CEILING: $190 USD (HIDDEN FROM RESEARCHER)

Lowest Bounty Floor | Tests PASS

Strategy Alpha — Minimal Surgical AST Fix

SecLab Core Auditor (@sec_alpha)

Your Sealed Budget: **$190 USD**
Opening Market Ask: ~~$239 USD~~
Verified Bounty: $165 USD
Maintainer Saved: $74 USD

Zero-dependency minimal diff; fastest review & instant hotfix merge (30-Day Regression Guarantee)

Select Strategy Alpha

Best Value #1 | Tests PASS

Strategy Beta — Hardened Defense-in-Depth Patch

ZeroDay Shield Collective (@sec_beta)

Your Sealed Budget: **$190 USD**
Opening Market Ask: ~~$260 USD~~
Verified Bounty: $174 USD
Maintainer Saved: $86 USD

Recommended Best Value #1 — Strict input validation + sink parameterization (90-Day Security & Regression Warranty)

Selected Remediation Patch

Enterprise Hardening | Tests PASS

Strategy Gamma — Full Zero-Trust Boundary Suite

Aegis Formal Verification Lab (@sec_gamma)

Your Sealed Budget: **$190 USD**
Opening Market Ask: ~~$307 USD~~
Verified Bounty: $184 USD
Maintainer Saved: $123 USD

Strict allowlist enforcement + audit trail stamp for regulated production APIs (180-Day Enterprise SLA Coverage)

Select Strategy Gamma

3. VERIFIED UNIFIED GIT DIFF (STRATEGY BETA — HARDENED DEFENSE-IN-DEPTH PATCH)

SHA-256: 1D743EC800FA079E

```
--- a/targets/fintech_ledger_api/ledger_service.py
+++ b/targets/fintech_ledger_api/ledger_service.py
@@ -1,8 +1,3 @@
-"""
-Real vulnerable microservice module #1: Fintech Account & Webhook Ledger Service.
-Contains genuine CWE-89 SQL Injection in `lookup_account_by_owner()` that can be
-exploited before patching and verified safe after parameterized patching.
-"""
 import sqlite3


@@ -25,8 +20,11 @@


 def lookup_account_by_owner(conn: sqlite3.Connection, owner_handle: str) -> list[tuple]:
+    if not isinstance(owner_handle, str) or len(owner_handle) > 64:
+        return []
     cur = conn.cursor()
-    # VULNERABLE SINK (CWE-89): Direct string interpolation in SQL query allows authentication/data bypass
-    query = f"SELECT owner, tier, balance_inr FROM accounts WHERE owner = '{owner_handle}' AND tier != 'internal_admin'"
-    cur.execute(query)
+    cur.execute(
+        "SELECT owner, tier, balance_inr FROM accounts WHERE owner = ? AND tier != ?",
+        (owner_handle, "internal_admin"),
+    )
     return cur.fetchall()
```

4. 7-DAY COORDINATED SECURITY DISCLOSURE CALENDAR & DORADO TESTNET SETTLEMENT

0.05 TESTFET ESCROW

Today (22 Oct 2026)	Tomorrow (23 Oct 2026)	Sat, 24 Oct (24 Oct 2026)	Sun, 25 Oct (25 Oct 2026)	Mon, 26 Oct (26 Oct 2026)
10:00 AM - 11:00 AM IST	03:00 PM - 04:00 PM IST	08:30 PM - 09:30 PM IST	10:00 AM - 11:00 AM IST	03:00 PM - 04:00 PM IST
Hotfix CI Merge Window	Staging Soak & Canary Gate	Low-Traffic Production Rollout	Hotfix CI Merge Window	Staging Soak & Canary Gate

Tue, 27 Oct (27 Oct 2026)	Wed, 28 Oct (28 Oct 2026)
08:30 PM - 09:30 PM IST	10:00 AM - 11:00 AM IST
Low-Traffic Production Rollout	Hotfix CI Merge Window

Confirm Patch & Settle 0.05 TESTFET on Fetch Dorado | CancelPayment (0 TESTFET Charged)